Fundamentals of Cybersecurity

Mohammad Hosseini

Faculty of Computer Science and Engineering
Shahid Beheshti University

Network

Denial of Service



What is a Denial of Service (DoS) attack?

- A malicious attempt to disrupt the normal functioning of a system, service, or network.
  - Goal: To render the target unavailable to legitimate users.
    → Users are denied access to authorized services or data.
- No data breach; focus is on availability.
  - Confidentiality and integrity are concerned with preventing unauthorized access; availability is concerned with preserving authorized access.
- A major concern for businesses and critical infrastructure.

Denial of Service

- **Confidentiality** and **integrity** tend to be **binary**.
  - Data or objects either are or are not kept private and unmodified.
- **Availability** can be more nuanced, in that there may be service but in insufficient quantity or at unacceptable responsiveness.
- Denial of service ranges from complete loss of access to noticeable and unacceptable slowing to minor inconvenience.

How do DoS attacks work?

- Overloading resources
  - Flooding the target with traffic until it's overwhelmed.
- Exploiting vulnerabilities
  - Attacking weaknesses to crash the system.
- Blocking access to the resource
  - Cutting or disabling the communications link between two points.

Types of DoS attacks

- Volumetric attacks
  - Flooding the network with large amounts of data. (e.g., UDP Flood, ICMP Flood)
- Protocol attacks
  - Exploiting weaknesses in network protocols. (e.g., SYN Flood, Smurf Attack)
  - Interfering with the network routing mechanisms, preventing access requests from getting to the server.
- Application layer attacks
  - Target specific applications or services. (e.g., HTTP Flood, Email flood)
  - Exploit a vulnerability in an application and cause the application to crash.
  - Manipulating access control data, deleting access permissions for the resource, or to disable the access control mechanism so that nobody could be approved for access.

Real world examples

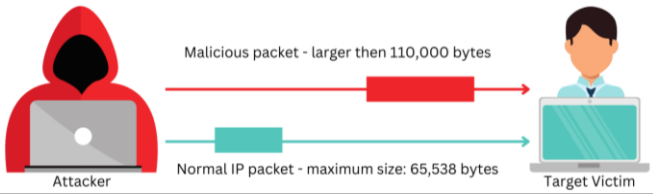
- Attack to Ireland health service (2021)
- GitHub attack (2018)
  - Largest recorded DDoS attack at 1.35 Tbps
  - It was an amplification attack using public Memcached servers

Flooding

- The most common malicious DoS attack type is flooding
- An attacker can try to overload a server by presenting commands more quickly than the server can handle them.
  - Servers often **queue** unmet commands during moments of overload for service when the peak subsides.
  - but if the commands continue to come too quickly, the server eventually runs out of space to store the demand.
- Flooding a victim is basically an unsophisticated attack, although the means of performing the flooding can become sophisticated.
  - If the attacker's bandwidth is greater than that of the victim, the attacker can overwhelm the victim with the asymmetry.
  - A victim is always **potentially vulnerable** to an attacker with more resources.

Ping of Death attack

- The `ping` (ICMP) command is used to test connectivity between two devices.
- Normally, the packet size is small (e.g., 32 or 64 bytes).
- In a Ping of Death attack, the attacker sends an oversized ICMP packet (greater than the maximum allowed size of 65,535 bytes).
  - The large packet is **fragmented** into smaller pieces during transmission to fit within the size limit of individual packets.
  - When the target system receives the fragments, it attempts to **reassemble** them into the original oversized packet.
  - Older systems with poorly implemented reassembly processes could experience **buffer overflows** or **crash**
- The original ping of death attack is less common today. A related attack known as an ICMP flood attack is more prevalent.

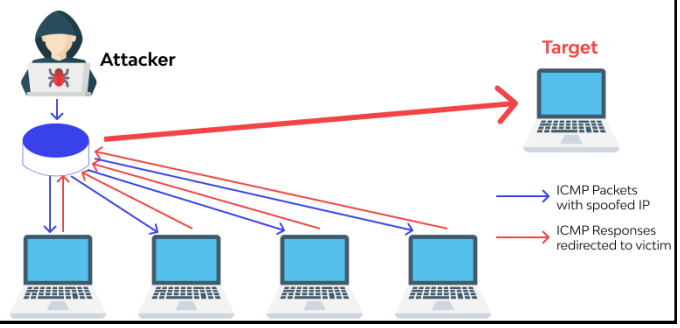


ICMP flooding

- The attacker floods the target system with a huge number of `ICMP Echo Request` packets.
- The target system tries to respond to each of these requests with an `Echo Reply`, consuming its CPU, memory, and bandwidth.
- If the volume of requests is high enough, the target becomes overwhelmed and unable to handle legitimate traffic.
  - The CPU and memory of the target system are consumed while processing the packets.
- The attack is limited by the smallest bandwidth on the attack route.

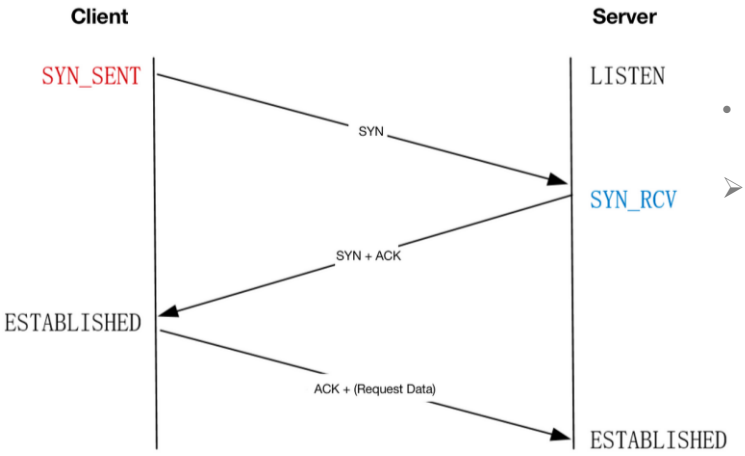
Smurf attack

- A broadcast address is used to send a message to all devices on a network (e.g., 192.168.1.255 sends to every device in the 192.168.1.x subnet).
- The attacker spoofs the source address in the ping packet so that it appears to come from the victim.
- Every device on the network receives the ICMP `Echo Request` and sends an ICMP `Echo Reply` to the spoofed source IP address (the victim).
- The attacker uses the entire subnetwork to multiply the attack's effect.



SYN Flood

- Exploits the TCP handshake process to overwhelm a target system.



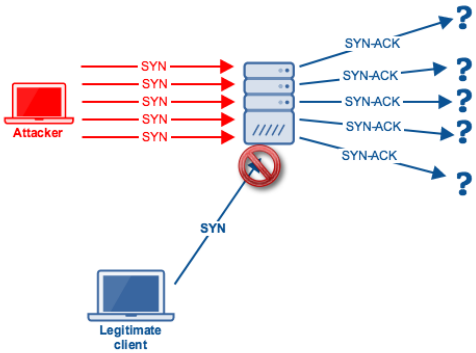
- Occasionally packets get lost or damaged in transmission.
  - ➢ The destination maintains a **queue** called the **SYN_RCV** connections, tracking those items for which a SYN–ACK has been sent but no corresponding ACK has yet been received.

SYN Flood

- The attacker sends a large number of SYN packets to the target server.
- The server responds to each SYN with a SYN-ACK, allocating resources for the connection, placing the connection in the SYN_RCV queue, and waiting for the client's ACK to complete the handshake.
- The attacker never replies with the ACK, leaving the connection half-open.
- The server keeps these half-open connections in a queue, consuming memory and CPU resources.
- When the queue is full, the server cannot accept new connections, causing a Denial of Service for legitimate users.

SYN Flood

- Attackers using this approach usually do one more thing:
  They **spoof** a nonexistent return address in the initial SYN packet.
  Why? For two reasons.
  - The attacker does not want to disclose the real source address in case someone should inspect the packets in the **SYN_RECV** queue to try to identify the attacker.
  - The attacker wants to make the malicious **SYN** packets indistinguishable from legitimate **SYN** packets to establish real connections.



DNS Spoofing

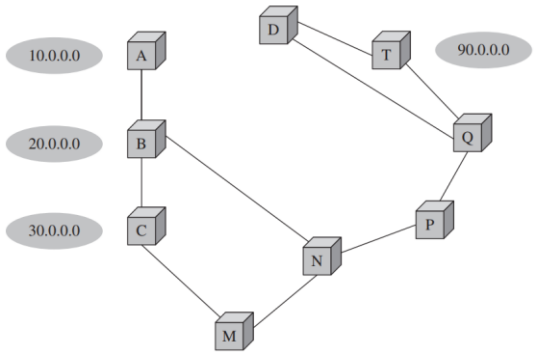
- DNS spoofing occurs when an attacker intercepts or manipulates DNS querying process, providing a fake IP address instead of the legitimate one.
  - DNS Cache Poisoning: Attackers exploit vulnerabilities in DNS resolvers to insert fake DNS records into their cache. (Solution: **DNSSEC**, uses digital signature)
  - Man-in-the-Middle: The attacker intercepts DNS queries between a user and a DNS resolver (or two DNS servers) and responds with a forged DNS response.
  - Compromising Authoritative DNS Servers: The attacker hacks into an authoritative DNS server and modifies its records. (Solution: DNSSEC)
  - Local DNS Spoofing: The attacker modifies the DNS settings on a user's device (e.g., by malware) to point to a malicious DNS server.

DNS flooding

- Another way to deny service through address resolution failures involves incapacitating the internet's DNS system itself.
  - 2002 massive flood attack to top-level domain DNS servers
  - 2007 massive flood attack to root DNS servers
    - ✓ The impact was significantly reduced to the anycast technology.

Rerouting Routing

- Each router in the Internet advertises its own subnet and its neighbor's (by the BGP protocol)
- **Trust-based protocol**: BGP assumes that all routers in the system are trustworthy and does not authenticate routing announcements by default.



- **No built-in validation**: BGP does not validate whether the advertised routes are legitimate (e.g., whether an AS actually owns the IP prefix it announces).

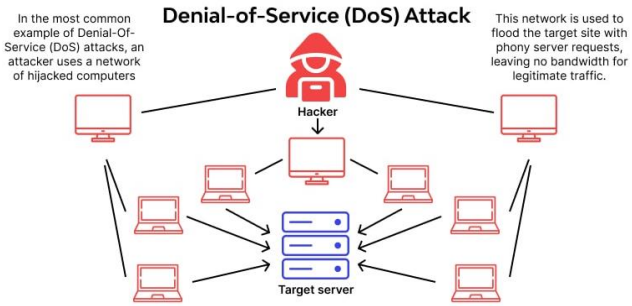
➢ A small misconfiguration or malicious update can propagate across the global Internet, affecting large portions of the network.

Some other DoS techniques

- Databases or **buffers** used for storing messages or emails can become overwhelmed by a sudden flood of incoming messages.
- **Log files** that store user activities or encountered errors can become filled due to the repeated execution of an action that triggers a log entry.
- Even **authentication** can become vulnerable to a DoS attack.
  - To protect against automated guessing attacks, some authentication services temporarily or permanently disable account access after some number of failed login attempts.
  - ➢ A malicious user can block access by repeatedly failing to log in as the victim.

Distributed Denial of Service

- DDoS attack involves multiple sources—often thousands or even millions of compromised devices—to flood a target with traffic or requests.
- The attacker plants a Trojan horse on many remote machines. Each of these compromised systems then becomes what is known as a zombie or bot.
- The attacker chooses a victim and sends a signal to the zombies to launch the attack.
- Neither the machines nor their owners are aware they are part of an attack
- No organization or accessible host is safe from attack.



Distributed Denial of Service

- Zombies are machines running pieces of malicious code under remote control.
- Because they may not interfere with or harm a user's computer (other than consuming computing and network resources), they are often undetected.
- Botnets, networks of bots, are used for massive DoS attacks, implemented from many sites working in parallel against a victim.
  - E.g., the Koobface bot network (2009)
- People who infect machines to turn them into bots are called **botmaster**s.
  - ➢ Botmasters sometimes rent out their botnets to others.

Coping with DDoS Attacks

- Administrators can address ordinary DoS attacks by means of techniques such as:
  - Tuning: adjusting the number of active servers
  - Load balancing: evening the computing load across available servers
  - Shunning: reducing service given to traffic from certain address ranges
  - Blacklisting: rejecting connections from certain addresses
- These same techniques are used against DDoS attacks, applied on a larger scale and at the network perimeter.